Pixel Paddle pre-launch QA report

Nov 6, 2026 · @UBS

Verdict: go after the second pass, pending the production steps below. The first pass was no-go: 6 critical and 14 high findings would corrupt tournament results, leak player data across admin scopes, or take money with no way back. All are fixable before launch on Nov 15, 2026, but each needs a fix and a re-test.

Tested on `main` @ `1c25a49`: ~80 scripted API attacks, races and admin-scope abuse on the local docker stack; a 50-user load test; 36 routes × 3 widths (360/768/1366 px) × 3 roles in headless Chrome; independent security, business-logic and frontend code reviews; read-only checks on production (no logins, no load). Typecheck passes and 92/92 tests pass, but the lint step is a no-op in every package. Evidence: **LIVE** = reproduced, **PROD** = seen on production, **CODE** = verified in code only, **NLC** = race needing live confirmation. Full detail with file paths: `QA_RUN_2026-11-06.md` in the repo.

Second pass: fixes and re-test

All 6 critical and 14 high findings are fixed; 41 of 42 are closed (status column below), on branch `qa/prelaunch-fixes`, not yet committed. Re-tested on a freshly seeded stack: 4 attack suites (~110 checks), 108-page responsive sweep and a 50-user load test. Typecheck is clean; tests pass: API 71/71, worker 56/57 (1 pre-existing skip), web 8/8.

Check	First pass	Second pass
Match result applied twice	rating 920 → 950 → 980	second call 409, rating unchanged
Scoped admin sees other venues' bookings	41/42 rows, 22 emails	0 rows out of scope
Completed tournament reopened	200	409
Book → cancel → rebook	409 forever	201, seat count exact
`/health` during 30 concurrent logins	4,458 ms	11–104 ms
Public tournament list, 50 users	170 req/s	435 req/s
Tap targets under 32 px (108 pages)	425	81, inline text links only
Blank pages / unlabelled inputs	404 blank; up to 9 per form	0 / 0

Found and fixed in this pass:

- **Logins froze the API under load:** `bcryptjs` hashed on Node's main thread. Swapped to native `bcrypt@6`; existing hashes still log in.
- **`docker compose up` failed on a fresh machine** (Postgres healthcheck race) and **`pnpm migrate:up` broke** on the new migrations. Both fixed.
- **Slot days were bucketed in UTC.** Slot lists and generation now use the browser's time zone, DST-safe.
- **Tournament admins hit a 403 adding players.** New scoped player lookup, public fields only.
- **Play flow dead end.** A closed or knockout tournament let a new player pick venue and slot before failing; now refused up front. "Round 101" now reads "Quarter-finals".
- **Market copy** said "Canada's first" in 6 places while every venue is in Pakistan; now market-neutral.
- **VR Tournament button:** new `GET /api/v1/integrations/meta/tournaments/live` returns `hasLiveTournament` for open or in-progress tournaments (docs §5.5). Both states verified.

Before launch:

- [ ] Rotate `META_API_KEY` on prod (it is in git history) and send the new key to the Meta team; confirm prod JWT secrets aren't dev values, or the API now refuses to start
- [ ] Apply the nginx security headers from `docs/DEPLOYMENT.md`; check the payment form for CSP errors
- [ ] Back up the prod DB, run migrations 017–018, `pnpm install` (new `bcrypt` dependency)
- [ ] Real SES credentials: password reset and all emails are logged, not sent, until then
- [ ] Legal review of the Terms and Privacy copy; replace the placeholder `support@pixelpaddle.com`
- [ ] Confirm the seed accounts (`admin@vrtournament.com` / `password123`) don't exist in the prod DB
- [ ] Stripe test-mode run (decline → retry, refund) and a real-phone pass (iOS Safari, Android Chrome)
- [ ] Set up ESLint so CI's lint step checks something (M22)

Critical: launch blockers

Six findings break core promises: fair results, admin data boundaries, and taking payment only for what is delivered.

ID	Finding	Evidence	Where	Fix	Status
C1	**A match result can be applied twice.** Setting a result twice moved rating 920 → 950 → 980, wins 2 → 3 → 4, round 101 → 102 → 103, and dropped the player from `knockout` back to `active`. Flipping the winner afterwards kept the phantom wins and marked the original winner eliminated. Also reachable with no admin: bot-chase score submit racing the headset poll (NLC).	LIVE	`lib/match-outcome.ts:153`, `:58`; `meta.service.ts:245`	Guard the completing UPDATE on status, return early on 0 rows; reject setResult on completed matches unless reversing.	Verified
C2	**Scoped admins act and read outside their scope.** venue_admin of A created slots in venue B (201) and a new venue (201). tournament_admin read 41/42 out-of-scope bookings with 22 player emails, 64/87 matches, 100/100 users' notifications. venue_admin read 440/500 slots and 48/48 tournaments incl. drafts.	LIVE	`slots.routes.ts:26`, `venues.routes.ts:34`, `tournaments.routes.ts`, admin list services	Delete the public create routes; filter every admin list by scope.	Verified
C3	**Editing a tournament shifts all four dates on every save** — 5 hours earlier per save for an admin in Pakistan, even with no changes.	CODE	`pages/admin/TournamentFormPage.tsx:120-123`	Fill datetime-local inputs from local getters, not `iso.slice(0,16)`.	Verified
C4	**The last superadmin can demote themselves** (200). Nothing in the app can restore one; happened during testing and needed a DB reseed.	LIVE	admin users update	Block self role changes and any change leaving zero superadmins.	Verified
C5	**No tournament lifecycle guards.** A completed tournament was republished (now `open`) and restarted (now `in_progress`). `complete()` leaves rounds open; `delete()` cascades paid buybacks.	LIVE	`admin/services/tournaments.service.ts:179-231`	Explicit from→to allow-list; close rounds in `complete()`; block delete with matches or buybacks.	Verified
C6	**Players can be charged and get nothing, with no refund path.** Decline-then-retry success is ignored; buyback into T1 while live in T2 fails fulfilment and Stripe retries for 3 days; admin refund only accepts `completed` buybacks.	CODE	`lib/stripe.ts:150,163-168`, `tournaments.service.ts:1030`, `buybacks-notifications.service.ts:131`	Success beats failed; check live-tournament at checkout; auto-refund impossible fulfilments; refund any succeeded intent with an idempotency key.	Fixed

High: fix before launch

Fourteen findings that users or attackers will hit in the first weeks; four are proven live.

ID	Finding	Evidence	Where / fix	Status
H1	Slot creation accepts end before start, zero length, past times, capacity 1,000,000 and duplicates (all 201); 5,000 slots in one request held the API for 13.6 s.	LIVE	`shared/schemas/slot.ts:7` — refine times, cap capacity and array length, reject overlaps.	Verified
H2	Book → cancel → rebook the same slot fails forever (409). The same constraint makes pairing/confirm fail for anyone who once cancelled that slot.	LIVE	`migrations/…003:24` — partial unique index `WHERE status <> 'cancelled'`.	Verified
H3	One player can land in two live matches: pair lock TTL 4 s, released without an owner check, worker concurrency 3.	CODE/NLC	`worker/src/lib/redlock.ts:3,11` — owner-checked release or per-player advisory lock.	Fixed
H4	Seat counts drift through six paths (slot change in enter, failed register, uncapped finalize, declined match, admin status edits, cancel unlocking a match slot).	CODE	Derive counts in-transaction; add a `CHECK` on `booked_count`.	Fixed
H5	Live updates die after the first 15-minute token refresh: listeners stripped, reconnect uses the expired JWT.	CODE	`web/src/hooks/useSocket.ts:371-379` — callback auth, refresh on `connect_error`.	Fixed
H6	Two open tabs randomly log the user out (single-use refresh cookie, shared localStorage).	CODE	`web/src/lib/api.ts:93-111` — cross-tab lock around refresh.	Fixed
H7	`META_API_KEY` committed in `docker-compose.yml:64`; env validation accepts sample keys and dev JWT secrets in production.	CODE	Rotate the Meta key; fail startup on sample/dev values in prod.	In progress
H8	JWTs and refresh cookies are written to world-readable, unrotated logs (open since August).	CODE	`api/src/app.ts:41` — pino `redact`; install pm2-logrotate.	Verified
H9	Production player site `tournament.pixelpaddle.com` sends no CSP, HSTS, X-Frame-Options or nosniff (the API does). Token is in localStorage.	PROD	nginx SPA server block — add headers, `server_tokens off`.	In progress
H10	A late result at a round boundary corrupts standings: advancement reads the participant's current round, not the match's.	CODE/NLC	`match-outcome.ts:163` — use `match.round_number + 1`.	Fixed
H11	Withdrawing after the opponent batted gives them a hollow win: no win credited, no advance, knockout bracket stalls.	CODE	`tournaments.service.ts:1133-1135` — route through `applyMatchWinner`.	Fixed
H12	No 404 page: any wrong URL is a blank black screen.	LIVE	`web/src/App.tsx` — catch-all route.	Verified
H13	Mobile dead ends: admin drawer has no Log out or player-app link; player mobile menu has no Admin link.	CODE	`AdminLayout.tsx:130`, `AppLayout.tsx:225,289-335`.	Fixed
H14	No self-service forgot-password; register demands accepting Terms but no Terms or Privacy page exists.	CODE	Add both; reset needs working email (see Low).	Fixed

Medium

Twenty-two findings; M1–M8 touch players or admins every day and should go first.

ID	Finding	Evidence	Status
M1	Account enumeration by timing: unknown email answers in 10–40 ms, a real account in 700–900 ms (bcrypt skipped). `check-availability` also confirms emails. `auth.service.ts:102`	LIVE	Verified
M2	Weak passwords accepted (`12345678`); the UI meter says "Weak" but still submits.	LIVE	Verified
M3	Admin can create a match of a player against themselves (201); any status jump allowed.	LIVE	Verified
M4	Match card contradicts itself: "Your target is set" + "Waiting on the first innings" + "Both innings are in". A casual match sat `in_progress` 15+ min with a stored result and no innings. `MatchesPage.tsx:307,345,409`	LIVE	Verified
M5	Dates show as `11/6/2026, 7:00:00 PM` (reads as 11 June in Pakistan); slot picker "Today" built from UTC; venues have no timezone.	LIVE + CODE	Verified
M6	Load errors look like empty data ("No bookings yet" on a 500); detail pages skeleton forever on 404.	CODE	Fixed
M7	Scoped admins see superadmin-only buttons and only learn via a 403 after filling the form.	CODE	Fixed
M8	Login ignores `returnTo` (set by the guard, seen live); everyone lands on `/venues` .	LIVE + CODE	Fixed
M9	Edit-participant modal steals focus on every keystroke. `ui/modal.tsx:69`	CODE	Fixed
M10	Admin edit forms are overwritten by background refetches, losing unsaved edits.	CODE	Fixed
M11	No confirmation on cancel booking, withdraw, decline match; a failed cancel silently restores the row.	CODE	Fixed
M12	Bots appear in standings, can take advancement spots or win. `bot-opponent.ts:63-77`	CODE	Fixed

ID	Finding	Evidence	Status
M13	`expire-matches` can expire a just-confirmed match (no status guard).	CODE	Fixed
M14	Buyback double-click makes two PaymentIntents; 1–49 cent prices allowed; refund not idempotent.	CODE	Fixed
M15	Players with history can't be deleted (blocks data-deletion requests); venue delete cascades VR round slots.	CODE	Fixed
M16	Public tournament list is the slowest hot path: 170 req/s, p50 290 ms at 50 users (venue search: 900 req/s, 51 ms). Likely first to saturate on the 3.9 GB VM.	LIVE	Verified
M17	Admin password reset leaves live access tokens valid up to 15 min.	CODE	Fixed
M18	`getClientIp` trusts the first `X-Forwarded-For` value and puts it unvalidated into geo URLs.	CODE	Fixed
M19	4 MB JSON body limit on every route; only avatar upload needs it.	CODE	Verified
M20	Accessibility: 9 unlabelled inputs on the tournament form, 7 on new-user; unlabelled menu toggle and bell; match-found modal has no dialog semantics.	LIVE + CODE	Verified
M21	Tap targets under 32 px: 30 on tournament detail, ~20 on admin lists.	LIVE	Verified
M22	CI lint step is a no-op (`echo 'no lint configured'` in every package).	LIVE	Open

Low, polish and standing defects

Three production defects from August are still open in code: emails are logged instead of sent and marked `sent` when SES creds start with `sample` (`dispatch-notification.job.ts:50-53`); no ioredis client has an `error` handler, so a Redis blip can crash the API or worker; tokens in logs with no rotation (H8).

- Notification bell shows the raw type, never the message; dropdown overflows at 360 px; no outside-click or Escape close.
- Match-found "View match" only closes the modal instead of opening /matches.

- Buyback has no success state after paying; players can see "Stripe is not configured".
- Naming drift: "VR Tournament Platform" vs "VR Cricket League"; raw enums shown ("normal phase", `venue_admin`); "Lahore or Karachi" hardcoded.
- Dashboard drill-down `?status=` links are ignored; admin search fires on every keystroke.
- Three cache keys for `/players/me` leave username and role stale after a profile edit.
- Money uses a hardcoded `$` and `toFixed`; admins enter buyback prices in cents.
- Logged-in users can open /login and /register; the /matchmaking page is dead code; login uses `100vh` (iOS Safari).
- Phase-less admin matches never expire; a Redis restart drops casual queue entries; notification retries can re-send.
- Meta key compared with `===`; 4-digit Meta link codes; avatar type not sniffed; sockets return raw `err.message`; nginx shows its version.
- Test suites leak open handles on teardown.

What held up

The foundations are solid: no player-level IDOR, no injection, no layout overflow, and booking races resolve correctly.

Area	Result
Auth	`alg=none` and tampered JWTs rejected; refresh tokens single-use; token dead after logout; refresh cookie HttpOnly + SameSite=Strict; per-IP and per-account login limits work; same error for unknown vs wrong password; case-insensitive email
Player access control	Another player's match → 403, booking → 404, notification → 404; players and guests blocked from all 13 admin areas
Input handling	Malformed JSON, bad UUIDs, SQL-ish IDs, absurd paging → 400; 3.9 MB body handled; prototype pollution has no effect; all SQL parameterised
Concurrency	15 parallel bookings for 1 seat → exactly 1 success, counters right; 4 parallel cancels → 1 success; 10 parallel queue joins → 1 entry

Area	Result
Responsive UI	Zero horizontal overflow on 36 routes at 360 / 768 / 1366 px; zero console errors; admin tables scroll in place
Production edge	API sends full security headers; CORS allows only the app origin; TLS 1.0/1.1 refused; HTTP redirects to HTTPS; no `.env` or `.git` exposure

Not covered, and the path to launch

First, check whether the seed accounts (`admin@vrtournament.com` / `password123`) exist in the production database. If they do, that's a full takeover. I didn't try logging in to prod.

- [ ] Seed accounts absent from the prod DB; prod `.env` has no committed Meta key or dev JWT secrets
- [ ] Real Meta Quest flows end to end, including the C1 bot-poll race
- [ ] Stripe test mode: pay, decline-then-retry, refund (C6 is code-reviewed only)
- [ ] Real iOS Safari and Android Chrome, with menus and drawers opened
- [ ] Short ramp load test on a staging clone of the VM (not run on prod: risk of wedging the shared 3.9 GB box)
- [ ] Email delivery once real SES credentials are in

Suggested order of work:

1. Nov 7–8: C1, C2, C4, C5 (server-side guards, mostly small diffs), H7 key rotation, H8 log redaction, prod seed-account check.
2. Nov 8–9: C6 Stripe paths, H2 index, H1 slot validation, C3 date bug.
3. Nov 9–11: H3–H6, H9–H13 (concurrency, sockets, tabs, nginx headers, navigation, 404).
4. Nov 11–12: M1, M2, M4, M5, M6, M8, M11, M16.
5. Nov 13–14: full re-test of this report and the gaps above on staging and real phones.
6. Nov 15: launch only if every Critical and High is Verified.